

Exploiting an API endpoint using documentation

Topic: API Testing | Difficulty: Apprentice

Description

The application exposes interactive API documentation at /api without requiring authentication. The documentation reveals a DELETE endpoint for removing user accounts. An attacker can invoke this endpoint directly from the documentation interface or via a crafted HTTP request without any authorization.

Steps to Exploit

1. Navigate to /api on the target application.
2. Observe the interactive API documentation listing all available endpoints.
3. Locate the DELETE /api/user/{username} endpoint.
4. Send a DELETE /api/user/carlos request using the documentation UI or Burp Suite.
5. Confirm that user 'carlos' has been deleted.

Proof of Concept

Exposed docs:

```
GET /api HTTP/1.1 -> 200 OK, full API schema returned without authentication
```

Delete request:

```
DELETE /api/user/carlos HTTP/1.1
Host: TARGET
```

Response:

```
HTTP/1.1 200 OK (user deleted successfully)
```

Impact

- Unauthenticated access to all API functionality including destructive operations.
- Ability to delete any user account without authorization.
- Exposure of internal API structure and business logic to attackers.
- Potential for mass data manipulation via discovered API endpoints.

Mitigation / Remediation

1. Restrict API documentation endpoints to authenticated and authorized roles only.
2. Require authentication and authorization on every API endpoint.
3. Remove or password-protect API documentation in production environments.
4. Implement API gateway rate limiting, logging, and anomaly detection.

CVSS Score

CVSS v3.1: 9.1 (Critical)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

CVSS Justification

- Attack Vector: Network - accessible via browser.
- Attack Complexity: Low.
- Privileges Required: None.
- User Interaction: None.
- Confidentiality / Integrity: High - user data deletion and access.
- Availability: None.